Introduction

Faculty of Computer Science and Engineering, GIK

About me!

Zubair Ahmad

Education

- Ph.D. in Computer Science (Cyber Security) - University of Venice Italy (2020-2024)
- Visiting Research Scholar - CISPA Helmholtz Center for Information Security Germany
- European Parliament – EU AI Act 2023
- OPLSS Summer School Uni of Oregon and Boston Uni USA 2021

Research Interests

- Web Security and Privacy
- Data Privacy and Protection
- Internet and Web Measurements
- EU Compliance regulations, GDPR
- Internet of Things

More about me -->https://zahmaad.github.io/



Schedule

When?

- Wednesday – 6:30 PM
- Thursday – 3:50 PM

Where?

– Here!
– LH2 FCSE

Course Webpage

GitHub



What?

- Lectures
- Quizzes/Project/Class Activities
- Mid/Final Exams

Attendance?

- Mobiles in hands –> Mark as absent
- 80% mandatory
- 10 minutes threshold

Grading Policy

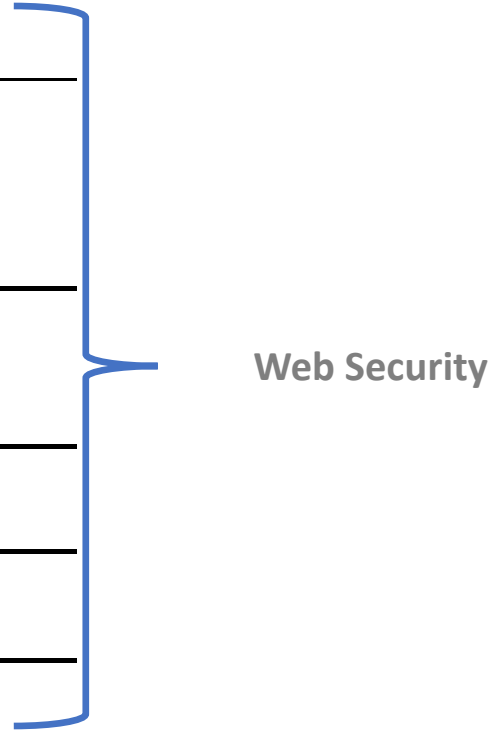
Assessment Items	Percentage
Quizzes	10%
Project	25%
Midterm Exam	25%
Final Exam	40%

Course Breakdown

Week 1	• Security Concepts • Importance of secure design • Security in the Software Development Life Cycle (SDLC) • Security concepts integrated into SDLC phases	SSDLC Basic Concepts
Week 2	• Risk Management in Software Projects • Security principles and secure design considerations • Designing secure design principles • Research Study	Risks Management
Week 3	• Security Mechanism • Mechanism and Policy • How to regulate access	Access Control
Week 4	• Common Vulnerabilities • Exploitation techniques and impacts	Security Vulnerabilities

Course Breakdown

Week 5	• Web security in the real world • Browser Security Mechanism • Building blocks for secure modern web applications.
Week 6	• Cross-site Scripting • Exploitation techniques and impacts
Week 7	• Online Tracking (1)
Week 8	• Online Tracking (2)



Course Breakdown

Week 9	• Security Testing (1) • Static analysis
Week 10	• Security Testing (2) • Dynamic analysis • Research Study

Security Testing

Course Breakdown

Week 11	• Taxonomy and classification of adversarial attacks on ML (1) • Threats and exploits
Week 12	• Taxonomy and classification of adversarial attacks on ML (2) • Threats and exploits
Week 13	• IoT Security (1)
Week 14	• IoT Security (2)
Week 15	• Final Q&A and discussions

IoT and ML Security

Reference Books

Reference books:

- Designing Secure Software: A Guide for Developers by Loren Kohnfelder (2023)
- Official (ISC)2 Guide to the CSSLP (latest)
- Software Security: Building Security In, 1st Edition by Gary McGraw

Additional books:

- Ross Anderson. Security Engineering. Wiley. 2nd edition.
- Mathias Paye. Software Security Principles, Policies, and Protection. (January 2019, v0.33)
- Theodor Richardson & Charles Thies. Secure Software Design. Jones & Bartlett Learning. 2013
- Secure by Design - Dan Bergh Johnsson, Daniel Deogun, Daniel Sawano – Manning 2019
- Architecture Patterns with Python - Harry Percival, Bob Gregory – O'Reilly 2020

Reference Materials

The main references for the course are many research papers in top-tier conferences and journals in computer security and machine learning. The following books are used for presenting background topics in machine learning and deep learning in the first part of the course.

1 Christopher M. Bishop, Pattern Recognition and Machine Learning, Springer, 2006.

2 Aston Zhang, Dive into Deep Learning, 2020

3 Ian Goodfellow, Deep Learning, MIT Press, 2016.

Information security conferences:

- IEEE Symposium on Security and Privacy (S&P)
- ACM Symposium on Computer and Communications Security (CCS)
- USENIX Security Symposium
- Network and Distributed System Security Symposium (NDSS)

Machine learning conferences

- International Conference on Learning Representations (ICLR)
- Neural Information Processing Systems (NeurIPS)
- International Conference on Machine Learning (ICML)
- IEEE/CVF Conference on Computer Vision and Pattern Recognition (CVPR)

Reference Materials

- Nicolas Papernot, ECE1784H, University of Toronto, 2019
- Bo Li, CS 498, University of Illinois at Urbana-Champaign, 2020
- Fei-Fei LI, CS231n, Stanford University, 2020
- Martin Vechev, Reliable and Interpretable Artificial Intelligence, ETH Zürich, 2020
- Yann LeCun, DS-GA 1008, NYU, 2020
- Nickolai Zeldovich, 6.858 MIT, 2014
- Bhiksha Raj, 11-785, CMU, 2021
- Mehdi Kharrazi, CE 40-817, Sharif U. T., 2015
- Papernot, Nicolas, et al. "Towards the science of security and privacy in machine learning." arXiv preprint arXiv:1611.03814 (2016).

Secure Software Design by Prof. Zeller – Saarland University Germany

https://www.st.cs.uni-saarland.de/edu/secdesign/

A Quick Starter Scenario

High Value Messaging System

Bank Own Staff

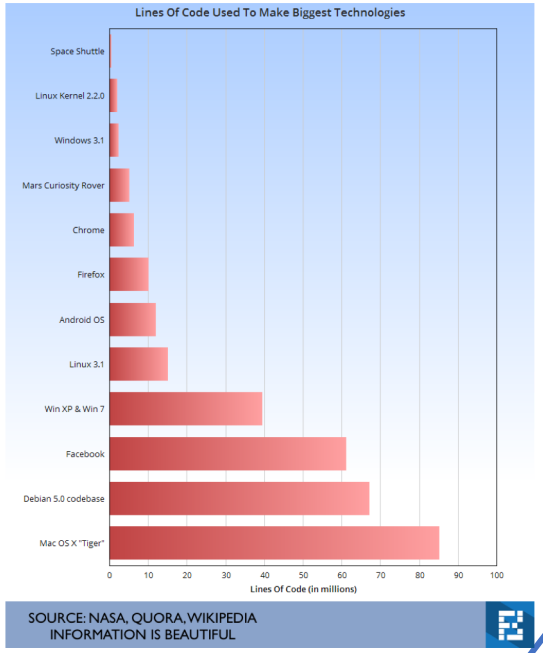


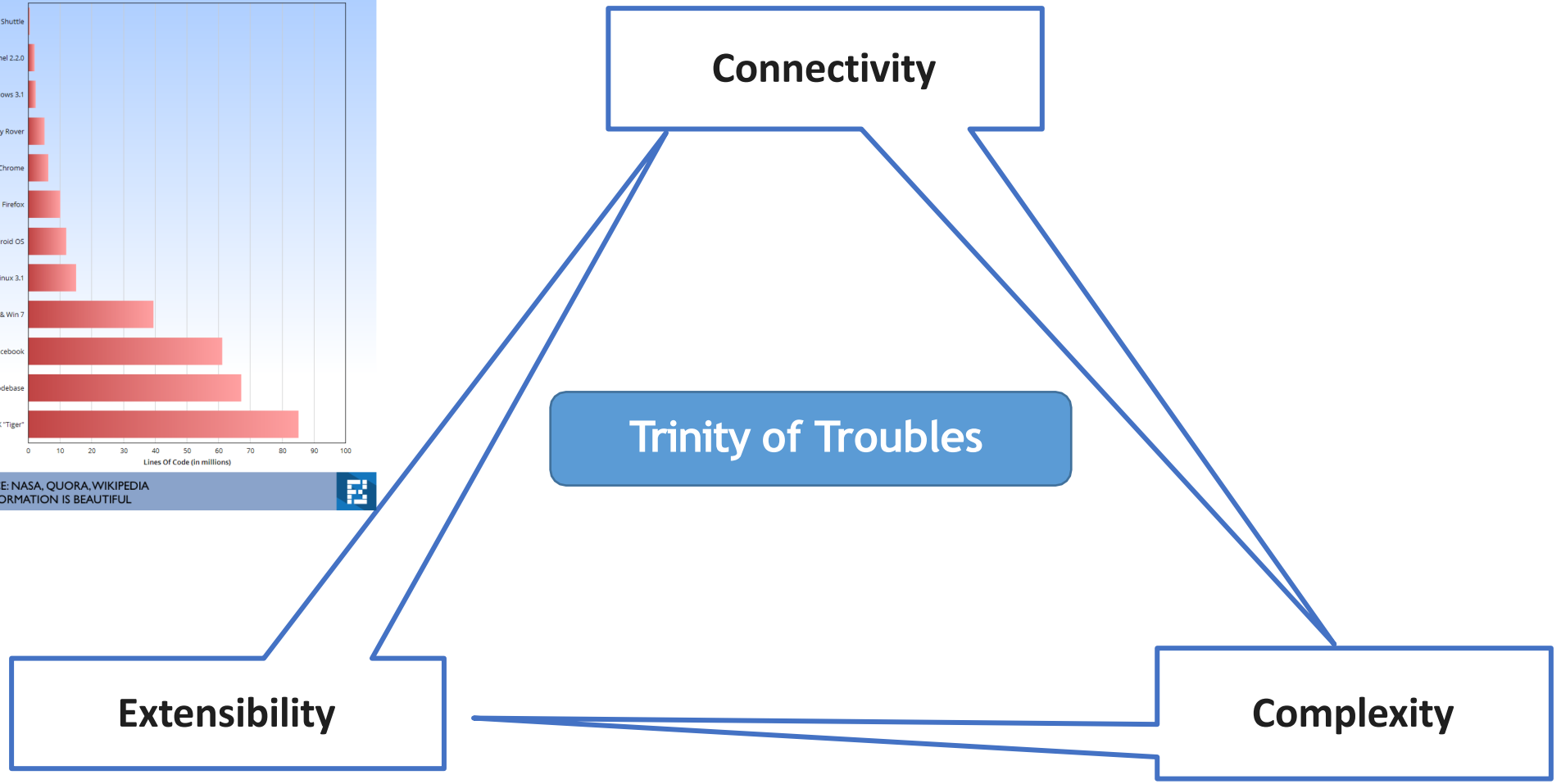
Physical Attack

ATM Machines

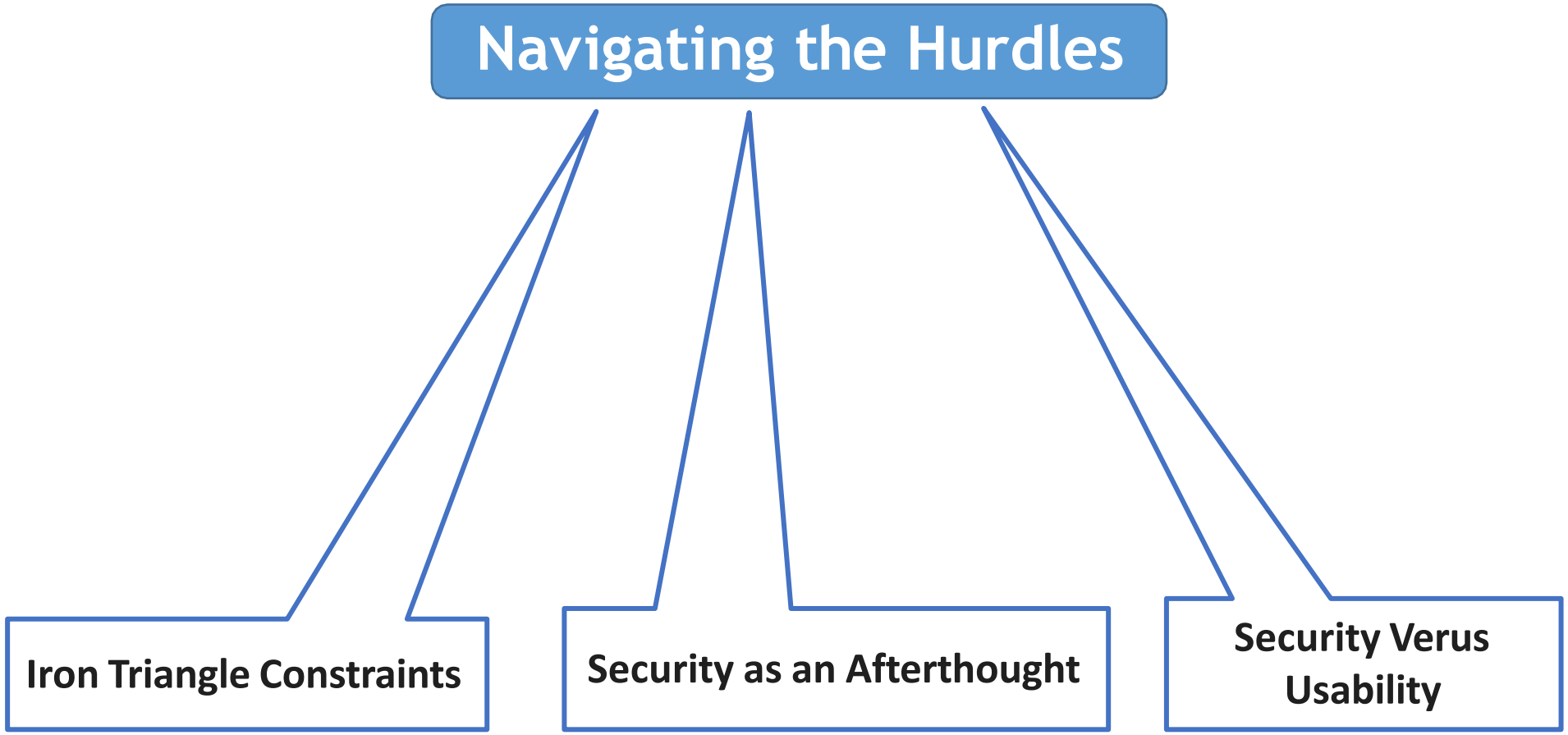
Website and Mobile App

Why the problem is growing?





Navigating the Hurdles



Iron Triangle Constraints

The attacker has the upper hand

Software development in and of itself is a resource, schedule (time) and budget intensive process

Resources (people) with appropriate skills and technical knowledge are not always readily available and are costly.

Scope = What we are building.

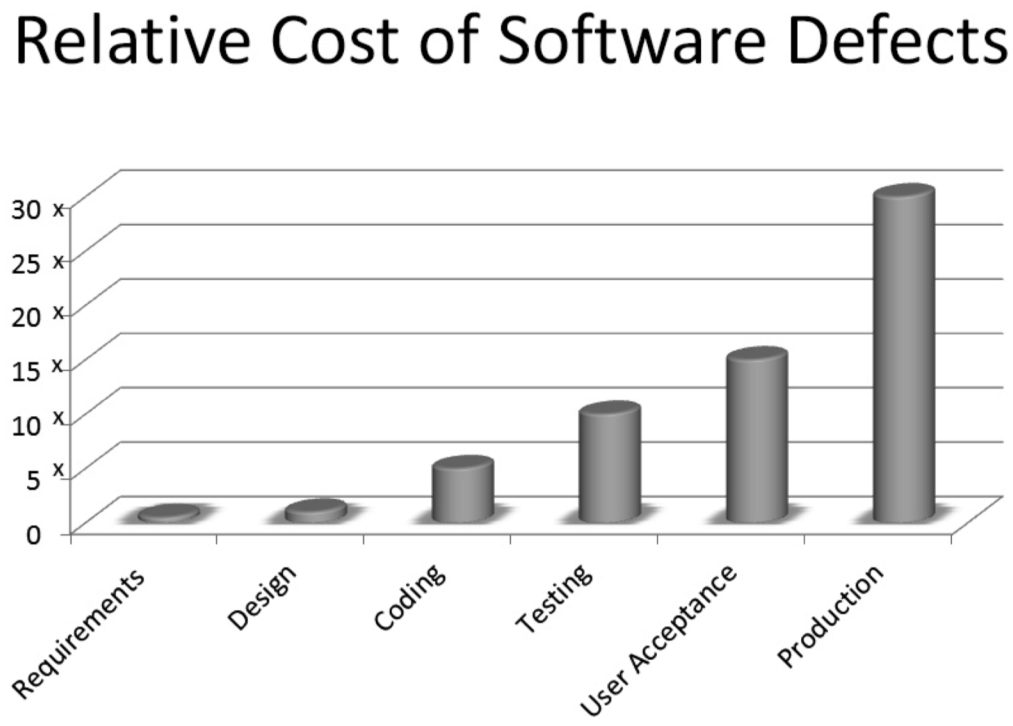
Time = When the software needs to be delivered.

Cost = Available budget and resources.



Security as an Afterthought

- **Security does not add any business value**
- **Secure features should be added at initial stage, instead at a later stage,**



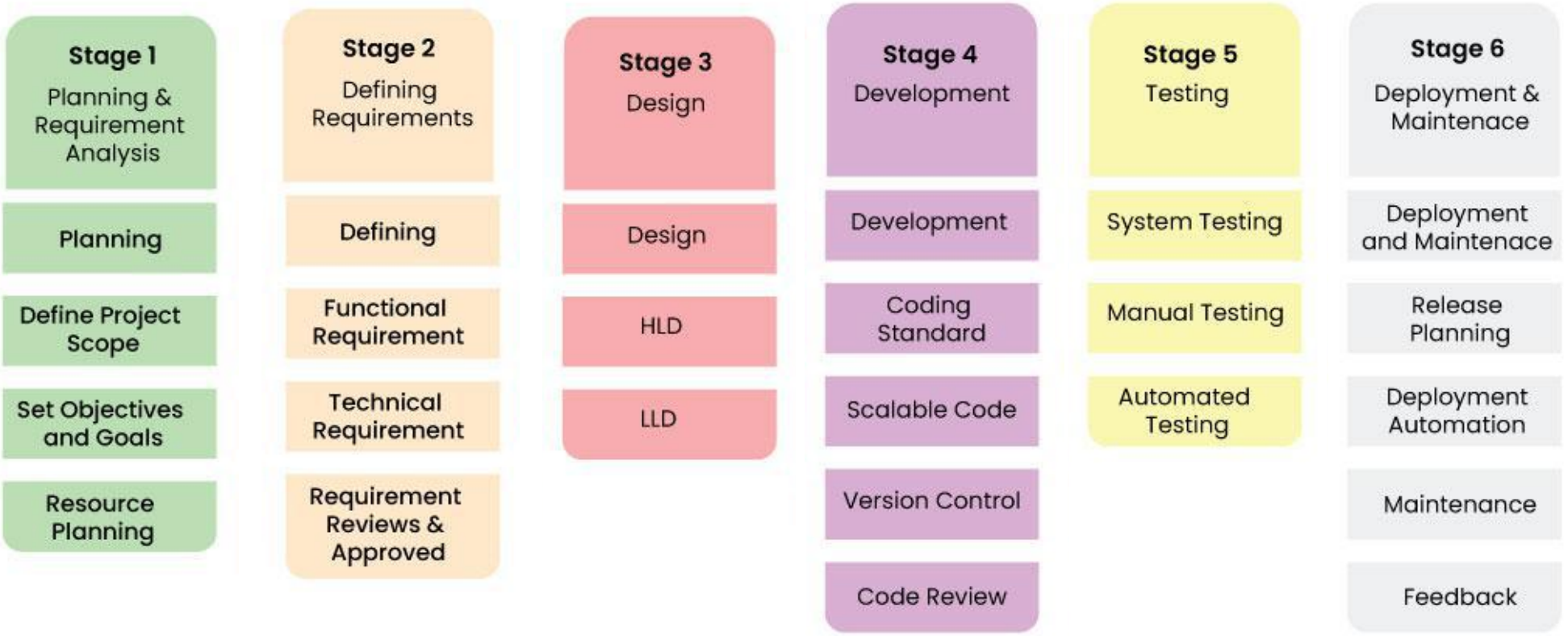
Security Versus Usabilty

More Security = Less Usability

- **Secure features is viewed as rendering the software to become very complex, restrictive and unusable**

- **A software product that is secure will add to the quality of that software but the inverse is not always necessarily true**

A Quick overview of SDLC



Waterfall Model (SDLC)

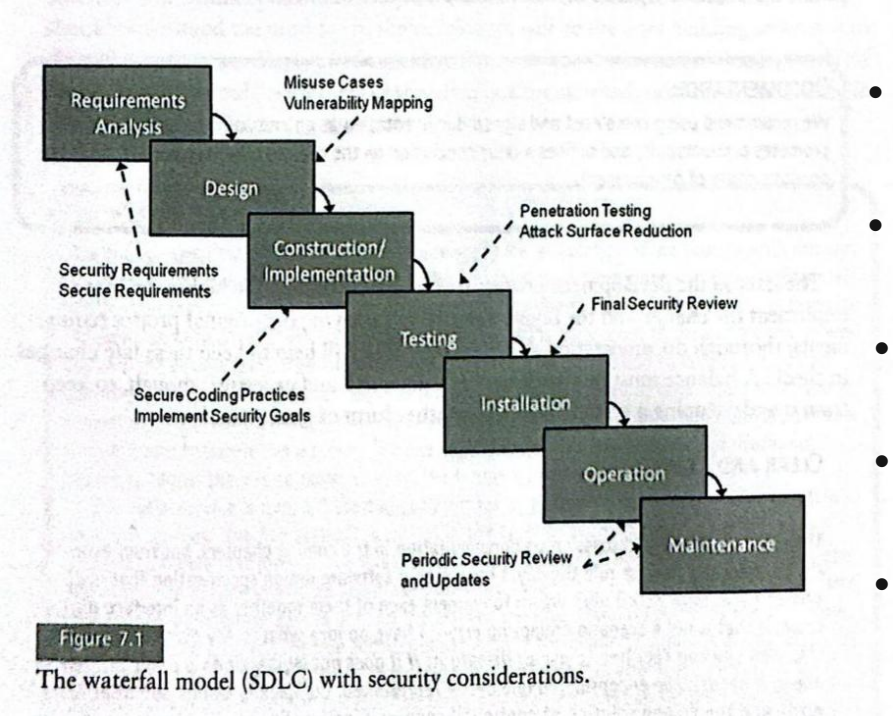


Figure 7.1
The waterfall model (SDLC) with security considerations.

- Tasks or activities into **six to eight phases**
- Cultural Change to adopt Security planning
- Scope of the project
- Functionality of the project
- Requirements of the project (Data, environment, etc

Scope Creep

Planning → **Develop** → **Deploy**

The Why in What and How

- Why did the breach happen?
- Why could they access it?
- Why wasn't permission checking implemented?
- Why didn't they know?
- Why wasn't it documented?

Why is Security Important in the SDLC?

Security related activities are deferred until the testing phase, which is late in the SDLC after most of the critical design and implementation has been completed

Shift Left



Shift Right



Planning and Requirement Stage



Planning and Requirement Stage



- Why should this **requirement** be part of the system?
- What are the constraints on this **requirement**?
- What are the dependencies for this **requirement**?
- What are the stakeholders for this **requirement**?

What if?

Fail Case

Result of Failure

Associated Risks

Planning and Requirement Stage

Confidentiality

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

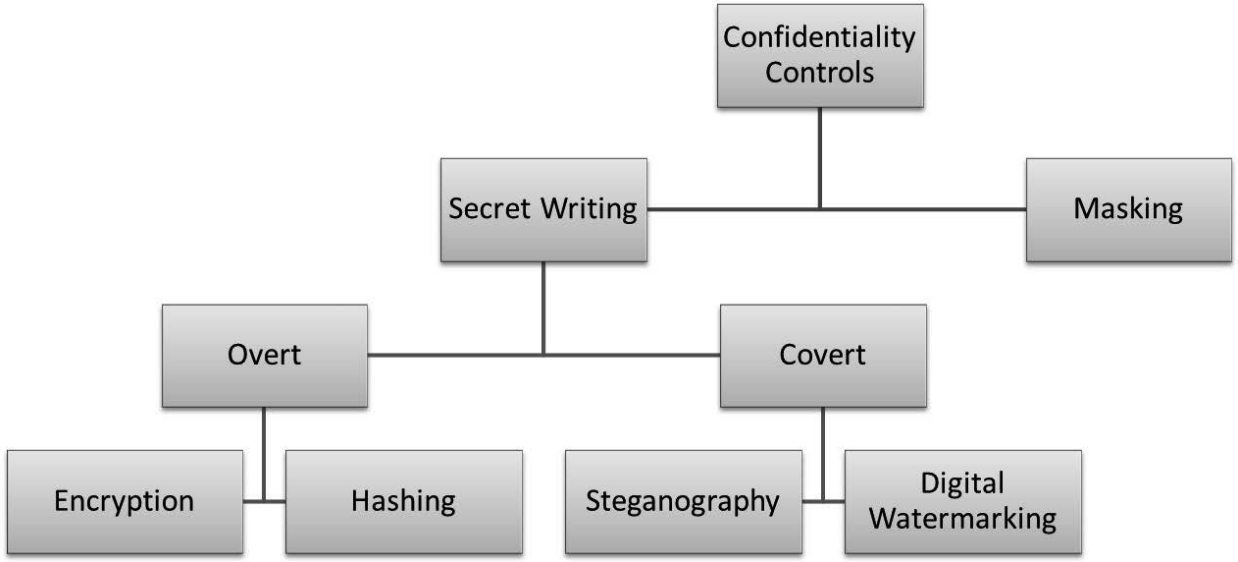
Address protection against the unauthorized disclosure of data or information that are either private or sensitive in nature

- **Data** can be broadly classified into **public** and **non-public data** or information.

Planning and Requirement Stage

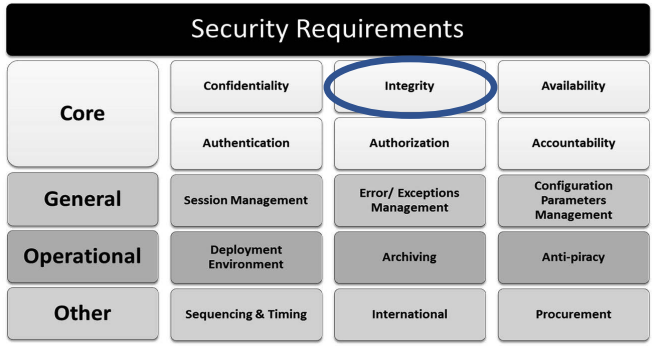
Confidentiality

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement



Planning and Requirement Stage

Integrity



System Integrity

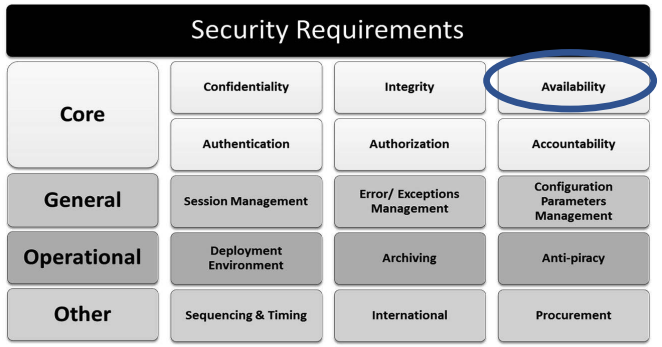
Reliability assurance and protection

Data Integrity

Prevention against unauthorized modifications

Planning and Requirement Stage

Availability



Maximum Tolerable Downtime (MTD)

Measure of the maximum amount of time that the software can be in a state of not providing expected service

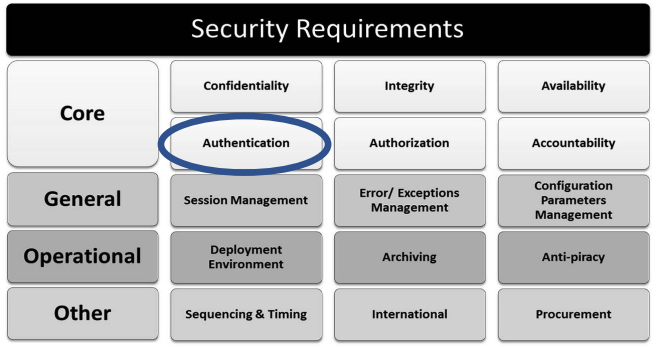
Recovery Time Objective (RTO)

Amount of time by which the system or software needs to be restored back to the expected state of business operations

- MTD are sometimes are referred to as Maximum Tolerable Period of Disruption (MTPD)

Planning and Requirement Stage

Authentication



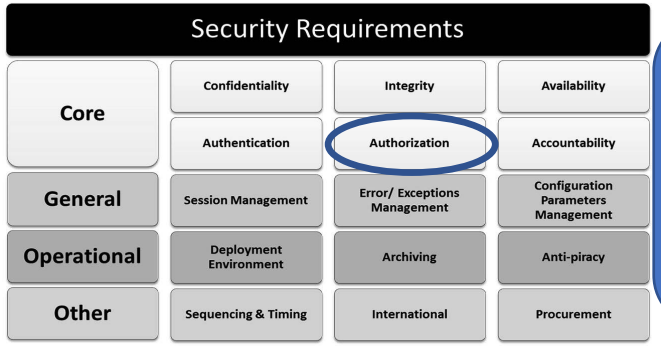
The process of validating an entity claim

- The entity may be a person, a process or a hardware device.

The most common forms of authentication??

Planning and Requirement Stage

Authorization

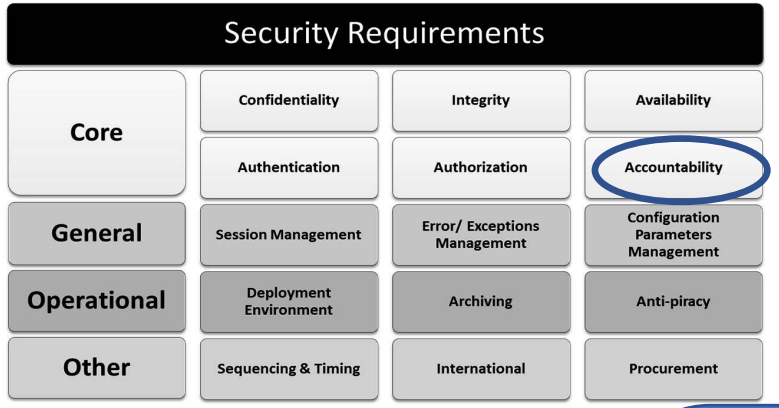


Layered upon **authentication**, authorization requirements are those that confirm that an authenticated entity has the needed rights and privileges to access and perform actions on a requested resource

- CRUD operations, which stand for **Create, Read, Update or Delete** data

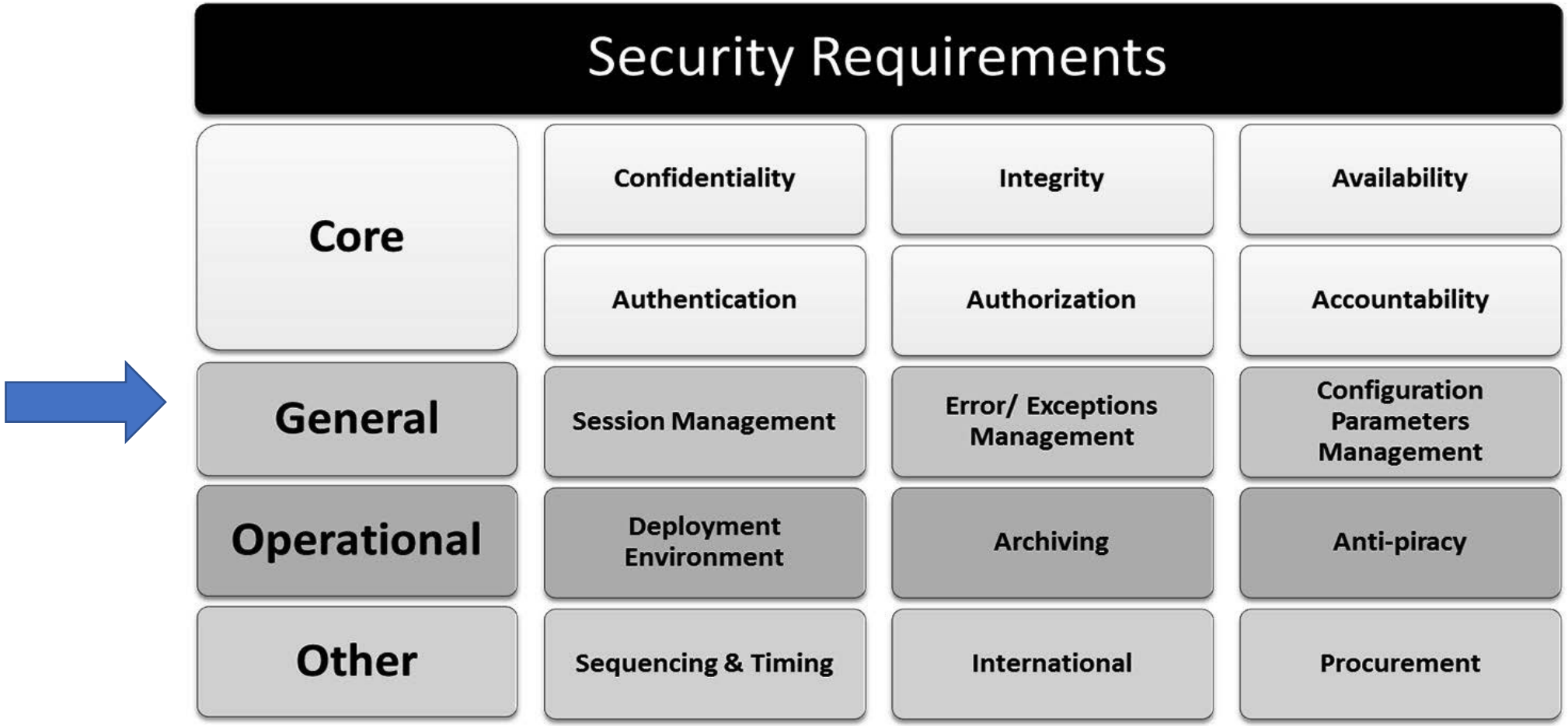
Planning and Requirement Stage

Accountability



- The identity of the subject (user or process) performing an action (**who**)
- The action (**what**)
- The object on which the action was performed (**where**)
- The timestamp of the action (**when**)

Planning and Requirement Stage



Planning and Requirement Stage

Session Management Requirements



Why we need session?

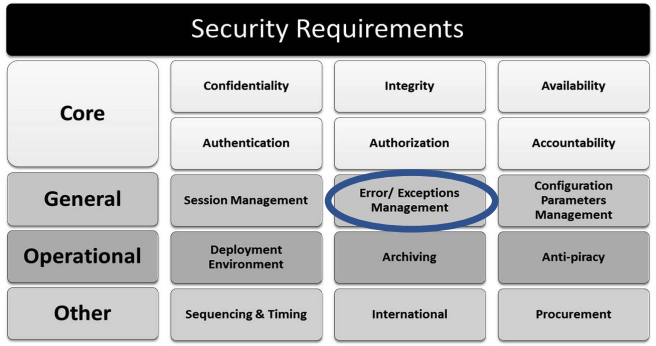
Since valid sessions can be potentially hijacked where an attacker takes control over an established session, it is necessary to plan for secure session management.

Related to which Secure Design concepts?

- Complete Mediation
- psychological acceptability

Planning and Requirement Stage

Errors & Exception Management Requirements



All about how you handle and structure the errors and exception

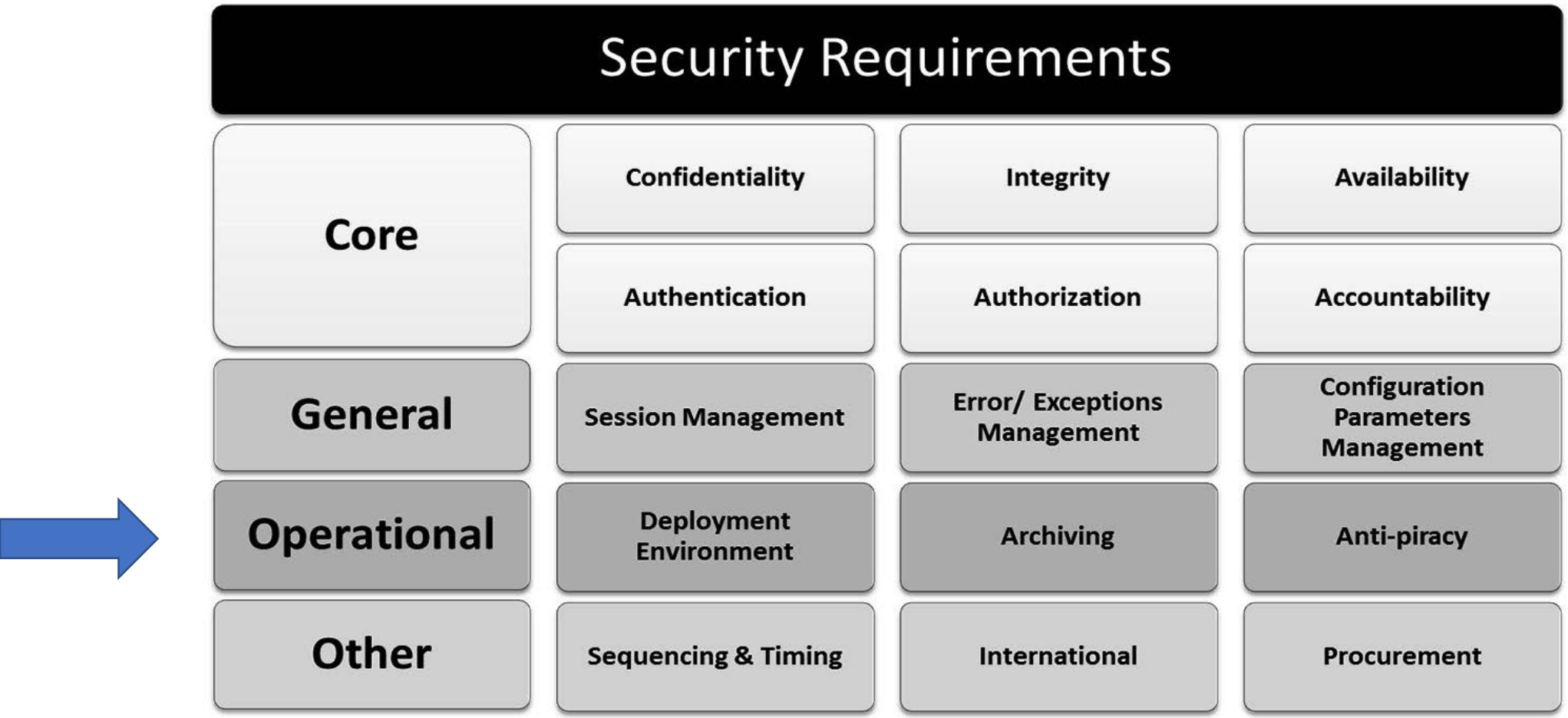
Can Errors & exceptions are potential sources of information disclosure?

Planning and Requirement Stage

Configuration Parameters Management Requirements



Planning and Requirement Stage



Planning and Requirement Stage

Deployment Environment Requirements

Security Requirements			
Core	Confidentiality	Integrity	Availability
	Authentication	Authorization	Accountability
General	Session Management	Error/ Exceptions Management	Configuration Parameters Management
Operational	Deployment Environment	Archiving	Anti-piracy
Other	Sequencing & Timing	International	Procurement

Requirements about the environment in which the software will be deployed

Deployment Environment Requirements



Will the software be deployed in an **Internet**, **Extranet** or **intranet** environment?

Can we leverage existing operating system event logging for auditing purposes?

Will the software be load balanced and how is clustering architected?

What privileges will be allowed in the production environment?

Will the software be transmitting sensitive or confidential information?

Will the software be hosted in a Demilitarized Zone (DMZ)?

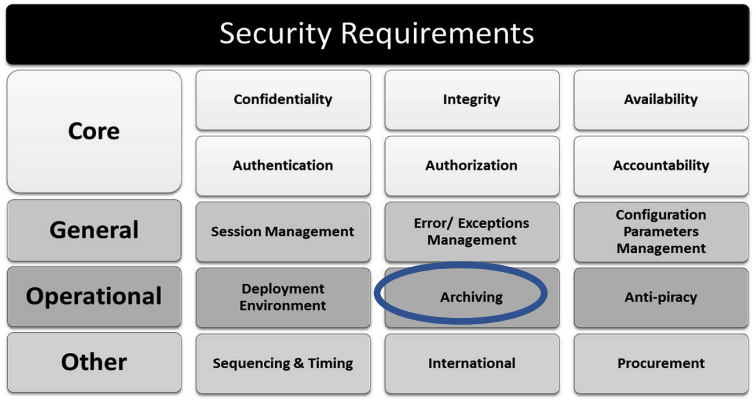
Will the software need to support single sign-on (SSO) authentication?

What ports and protocols are available for use?

Will the software be deployed in a **web farm environment**?

Planning and Requirement Stage

Archiving Requirements



conflict between the organizational policy and a regulatory requirement, then follow?

the *location, duration* and *format* of archiving information must be determined

Archiving Requirements



Where will the data or information be stored?

How do we ensure that the media is not re-writable?

How long will we need to store the archives for?

Is there a regulatory requirement to store the data for a set period of time?

Is our archival retention policy contradictory to any compliance or regulatory requirements?

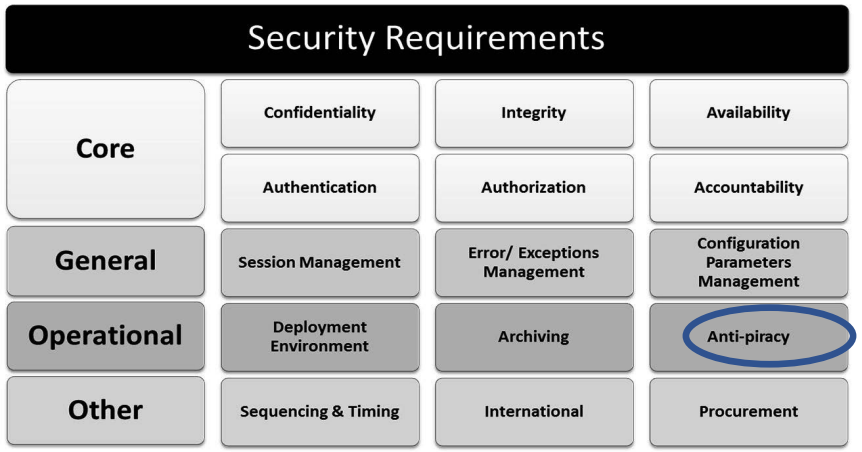
In what format will the data or information be stored? Clear text or cipher text?

If the data or information is stored in cipher text, how is this accomplish and are there management processes in place that will ensure proper retrieval?

How will these archives themselves be protected?

Planning and Requirement Stage

Anti-Piracy Requirements



Code obfuscation, anti-tampering, licensing and IP protection mechanisms should be included

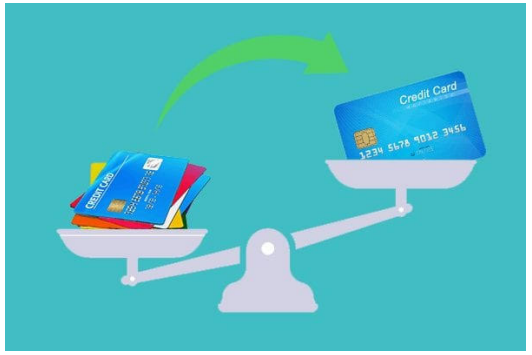
Vote only once by putting a cross ☒ in the box next to your choice
Should the United Kingdom remain a member of the European Union or leave the European Union?
Remain a member of the European Union ☐
Leave the European Union ☐

Security Needs Elicitation







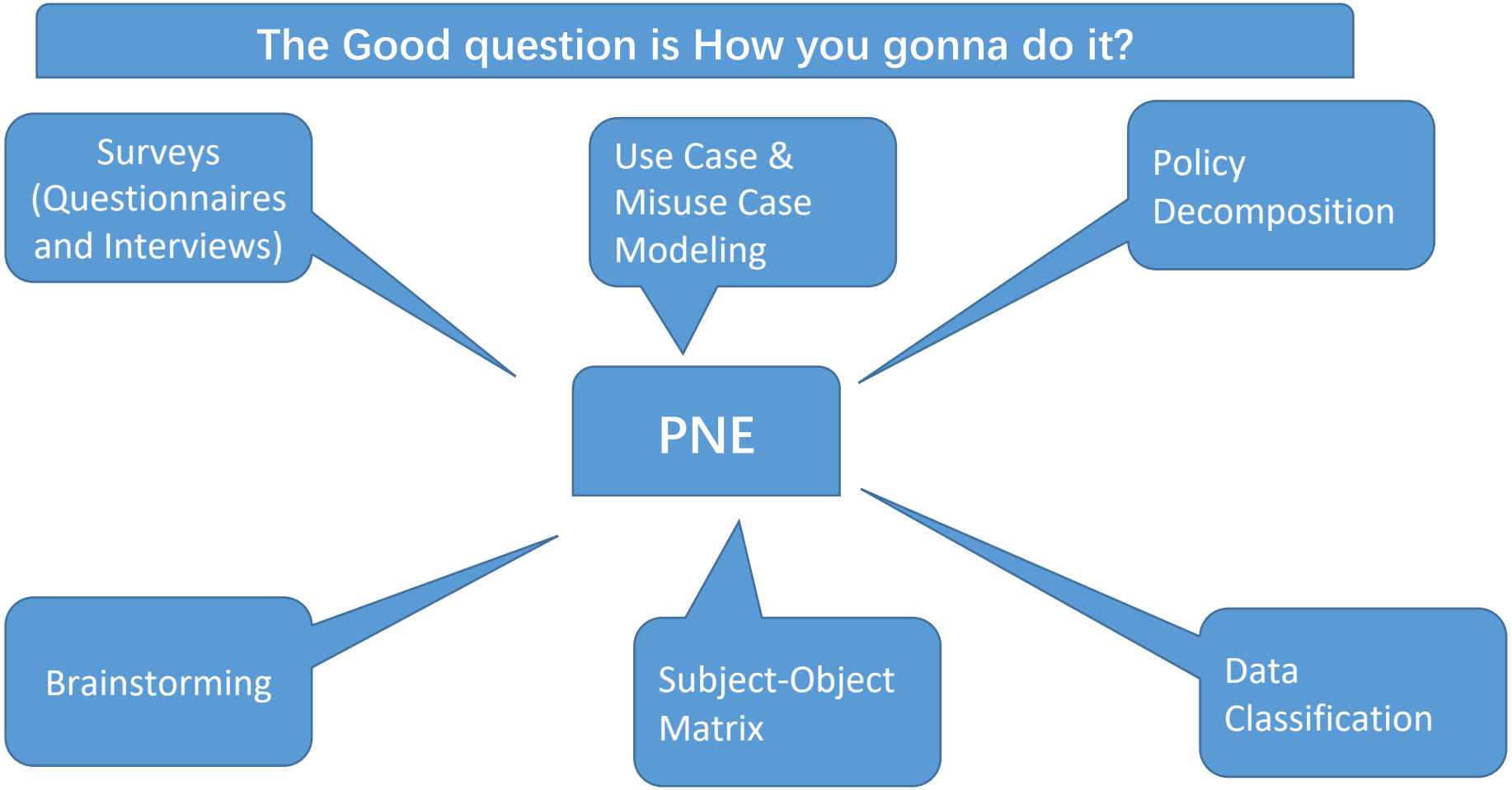




“What security questions should we ask this client before writing a single line of code?”

The process of discovering and documenting the security needs of a system by asking the right questions to the right stakeholders

Protection Needs Elicitation (PNE)



Protection Needs Elicitation (PNE)

Brainstorming → **Quick-and-dirty way**

- An exceptional method of eliciting a lot of innovative notions for a zone of curiosity

  How many choices are obtainable to get an answer to the existing problem just around the corner?
  - What aspects are compelling the group from moving forward with a method or choice?

- In what way can the problem be solved by a particular group?



Protection Needs Elicitation (PNE)

Brainstorming → **Quick-and-dirty way**

Shortcomings

- Brainstorming solutions are usually not comprehensive and consistent because it is very **subjective**

- High degree of likelihood that the brainstormed ideas don't directly relate to the business, technical and security context of the software

Surveys (Questionnaires and Interviews)

The effectiveness of the survey is dependent on how applicable the questions in the surveys are to the **audience** that is being surveyed

"Which cryptographic algorithm do you prefer for protecting your financial transactions?"

The questionnaires are not a one size fits for all type of survey

"Should the system require two-factor authentication?"

Both **explicitly specified questions** as well as **open ended questions** should be part of the questionnaire

"What security concerns do you have about the system?"

Policy Decomposition

One of the sources for security requirements is **internal organizational policies** that the organization need to comply with

the decomposition process is **objective** and compliant with the security policy, and not merely someone's opinion

"I think users should change their passwords every 30 days because that's more secure."

Data Classification

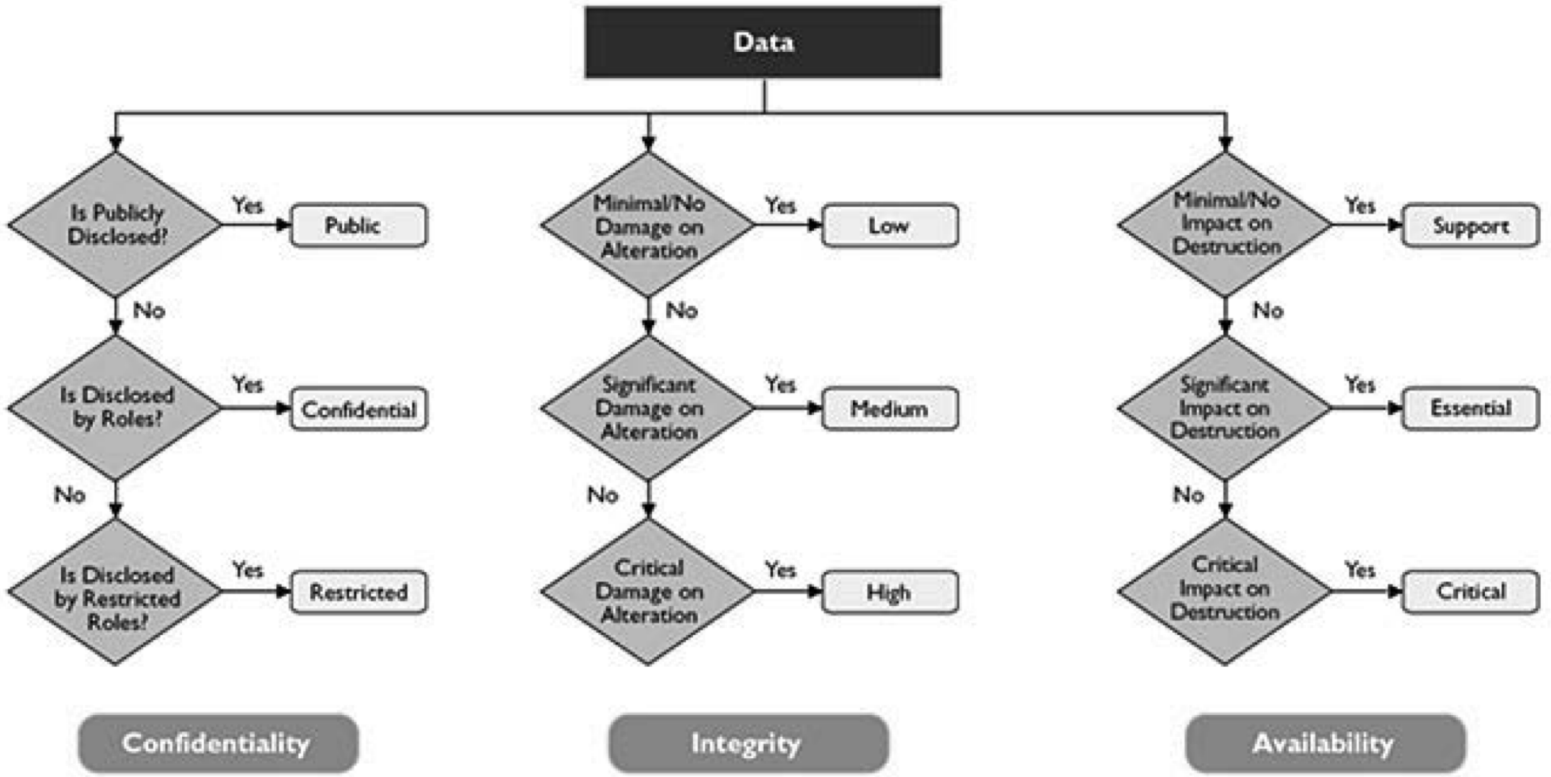
Data classification is based on CIA



Data classification can also assist in increasing the quality of risk based decisions

The **data quality and characteristics** are known upon classification, decisions that are made to protect them can also be made appropriately.

Data Classification



Subject/Object Matrix

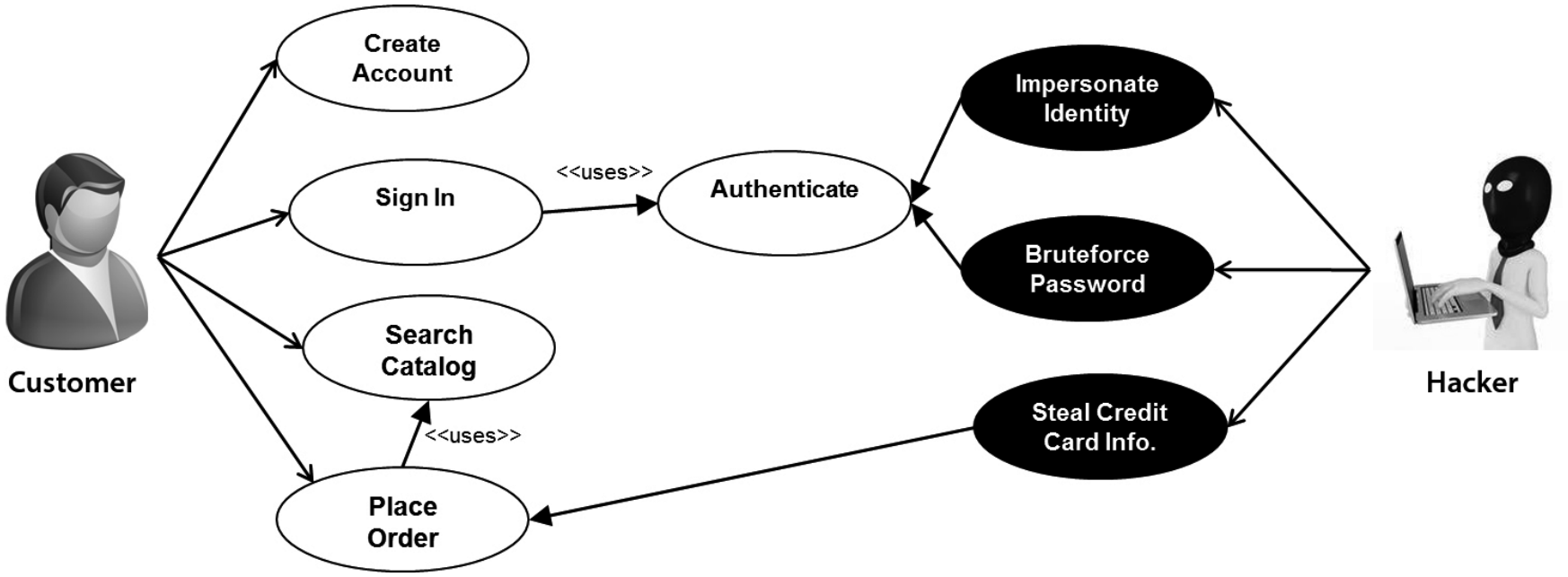
A **subject-object matrix** is a two-dimensional representation of roles and components

The **subjects** or roles are listed across the columns and the **objects or components** are listed down the rows

A subject-object matrix is a very effective tool to generate misuse cases

Who,
What,
What they are allowed to do?

Protection Needs Elicitation (PNE)



References

- Mano Paul - Official (ISC)2 Guide to the CSSLP CBK (2013, Auerbach Publications) - libgen.li

- Software-Security-Building-Security-In-by-Gary-McGraw-z-lib.org

Questions?